

Lineamientos de Privacidad, Seguridad y Gobernanza IA-LUMI

1. Nuestra Filosofía

LUMI Guardián AI diseña su operación siguiendo los principios de gestión de seguridad de la información de **ISO 27001** y de gobernanza de Inteligencia Artificial responsable de **ISO 42001** como marco de referencia. Nuestro sistema funciona actuando como un guardia en la puerta de tu servidor: observa la telemetría técnica, pero nunca inspecciona el contenido de tu negocio.

2. Caso de Uso y Alcance *MVP

En esta fase, LUMI Guardián AI está optimizado para proteger **servidores VPS que alojan tiendas online (e-commerce)**.

Aviso PCI DSS: Guardián AI protege la infraestructura del sistema operativo. **Si tu tienda procesa, transmite o almacena datos de tarjetas de crédito directamente en el VPS, es tu responsabilidad implementar los controles PCI DSS sobre la pasarela de pagos.** LUMI Guardián AI facilita este cumplimiento al proporcionar un entorno blindado a nivel de sistema.

3. ¿Qué datos recolectamos?

Dando cumplimiento a la legislación mexicana, recolectamos estrictamente lo necesario para operar el sistema:

- **Métricas de rendimiento:** uso de CPU, memoria y procesos activos, recolectados por el agente instalado en tu VPS.
- **Telemetría de accesos y disponibilidad:** intentos de conexión SSH y verificación del estado de HTTPS de tu servidor. El agente envía estos datos al backend por HTTP/HTTPS o WebSocket, junto con una señal periódica ("heartbeat") que confirma que sigue activo.
- **Datos de cuenta:** correo electrónico de los usuarios y credenciales de acceso al panel principal (las contraseñas se almacenan siempre con hash, nunca en texto plano).

Estado de cifrado en tránsito: estamos completando la configuración de HTTPS/TLS en toda la infraestructura antes de la disponibilidad general del servicio; hasta entonces, parte de la comunicación entre tu servidor, nuestra API y el Dashboard puede viajar sin cifrar. No ofrecemos todavía cifrado en reposo ni anonimización de la telemetría en base de datos; lo señalamos aquí en lugar de dar por hecho una protección que aún está en desarrollo.

4. ¿Para qué usamos estos datos y cómo actúa el sistema?

Los datos se evalúan en tiempo real contra los umbrales de alerta y el nivel de autonomía que configures para cada VPS (desde solo notificar, hasta bloquear de forma automática).

- **Trazabilidad:** cada acción automática de contención, como el bloqueo o desbloqueo de una IP, genera un registro (log) auditable que incluye: timestamp, evento disparador, regla o umbral aplicado y acción ejecutada.
- **Explicabilidad:** todos los incidentes se explican al usuario en lenguaje simple a través del panel de control.

5. Prevención de Riesgos Operativos (Modo "Soft" y Límites)

Para proteger la disponibilidad de tu tienda online:

- **Soft-Blocking:** las acciones de bloqueo se prueban primero en modo "auditoría" (alertando sin bloquear) o requieren validación humana a través de botones de acción rápida ("Bloquear/Permitir") ante casos ambiguos.
- **Límites de recursos:** el agente está diseñado para no exceder una cuota específica de CPU/RAM, asegurando que tu e-commerce siempre tenga prioridad.

6. Lo que NUNCA hacemos

No accedemos, procesamos ni almacenamos tu código fuente, bases de datos de clientes, correos electrónicos ni transacciones comerciales.

7. Retención y Control de Acceso

Los registros de seguridad se conservan por un tiempo limitado de 30 días según nuestra política de retención y luego se eliminan. Si cancelas el servicio, toda tu información, cuenta de usuario y telemetría asociada se elimina de forma segura en un plazo no mayor a 15 días.

Nota sobre roles y accesos: este documento describe nuestro compromiso de aplicar el principio de mínimo privilegio internamente; la separación formal de roles (Administrador, Auditor, Usuario) es parte de nuestra hoja de ruta y confirmaremos aquí el estado exacto de su implementación en la próxima revisión.

Notificación de Brechas: en caso de que nuestra infraestructura central sea comprometida, notificaremos a todos los usuarios afectados en un plazo máximo de 72 horas con las medidas de mitigación pertinentes.

8. Derechos ARCO

De conformidad con la LFPDPPP, puedes ejercer tus derechos de Acceso, Rectificación, Cancelación u Oposición contactando a nuestro equipo de privacidad.

